

Security Assessment Report

Simulazione di attacco ransomware tramite prompt AI

Executive Summary

Gli attacchi ransomware rappresentano una delle principali minacce informatiche per le organizzazioni moderne. Negli ultimi anni, gruppi criminali organizzati hanno sviluppato campagne sempre più sofisticate, mirate a compromettere infrastrutture aziendali, esfiltrare dati sensibili e cifrare i sistemi informativi per ottenere un riscatto economico.

Questo report descrive la progettazione di un **prompt strutturato per un sistema di intelligenza artificiale**, finalizzato alla simulazione di un attacco ransomware contro un'infrastruttura aziendale tipica. L'obiettivo è identificare vulnerabilità di sicurezza e fornire raccomandazioni operative per migliorare la resilienza dell'organizzazione contro questo tipo di minacce.

L'approccio adottato si basa su metodologie e framework riconosciuti nel settore della cybersecurity, tra cui:

- **MITRE ATT&CK Framework**
- **NIST Cybersecurity Framework**
- principi di sicurezza **Zero Trust**

Attraverso la simulazione di un attacco realistico, è possibile individuare i punti deboli dell'infrastruttura e implementare strategie efficaci di mitigazione del rischio.

Obiettivo dell'esercizio

L'obiettivo dell'esercizio è progettare un prompt in grado di guidare un sistema di intelligenza artificiale nell'analisi di uno scenario di attacco ransomware.

Il prompt deve consentire di:

- simulare un attacco ransomware realistico
- analizzare le diverse fasi dell'attacco informatico
- identificare le vulnerabilità presenti nell'infrastruttura aziendale
- proporre contromisure tecniche e organizzative

Questo approccio consente di utilizzare l'intelligenza artificiale come strumento di supporto per la **valutazione proattiva della sicurezza informatica**.

Metodologia

La simulazione dell'attacco ransomware segue le principali fasi utilizzate nelle campagne reali osservate nel panorama delle minacce informatiche.

Il modello di analisi si basa sulle tecniche descritte nel **MITRE ATT&CK Framework**, che rappresenta uno standard di riferimento per la classificazione delle tecniche utilizzate dagli attaccanti.

Le fasi principali considerate sono:

1. **Initial Access** – accesso iniziale alla rete aziendale
2. **Privilege Escalation** – ottenimento di privilegi amministrativi
3. **Persistence** – mantenimento dell'accesso al sistema compromesso
4. **Lateral Movement** – movimento laterale all'interno della rete
5. **Data Exfiltration** – esfiltrazione dei dati sensibili
6. **Impact** – distribuzione e attivazione del ransomware

Questa metodologia permette di analizzare in modo strutturato il comportamento degli attaccanti e di individuare le contromisure più efficaci.

Prompt progettato

Agisci come un **esperto di cybersecurity e threat intelligence specializzato nella prevenzione degli attacchi ransomware**.

Il tuo compito è supportare un'organizzazione di medie dimensioni nell'identificazione delle vulnerabilità della propria infrastruttura informatica attraverso la **simulazione di un attacco ransomware realistico**.

L'organizzazione utilizza una tipica infrastruttura aziendale composta da:

- workstation Windows
- server Windows e Linux
- Active Directory
- servizi di posta elettronica
- servizi cloud e file sharing
- accessi remoti tramite VPN

Esegui le seguenti attività.

1. Simulazione dello scenario di attacco

Descrivi un possibile scenario di attacco ransomware realistico indicando i principali vettori di ingresso utilizzati dagli attaccanti, tra cui:

- phishing tramite email
- credenziali compromesse
- vulnerabilità software
- servizi RDP esposti su internet
- sistemi non aggiornati

2. Analisi delle fasi dell'attacco

Descrivi le fasi dell'attacco seguendo il modello MITRE ATT&CK, includendo:

- Initial Access
- Privilege Escalation
- Persistence
- Lateral Movement
- Data Exfiltration
- Deployment del ransomware

3. Identificazione delle vulnerabilità

Individua le debolezze tecniche o organizzative che hanno reso possibile l'attacco, ad esempio:

- configurazioni errate dei sistemi
- mancanza di segmentazione della rete
- assenza di monitoraggio centralizzato
- politiche di sicurezza insufficienti
- scarsa formazione degli utenti

4. Raccomandazioni di sicurezza

Fornisci raccomandazioni tecniche per prevenire o mitigare attacchi ransomware, tra cui:

- implementazione di soluzioni **EDR o XDR**
- segmentazione della rete
- gestione efficace delle patch
- utilizzo dell'autenticazione multi-fattore (MFA)

- monitoraggio dei log e sistemi SIEM
- backup sicuri offline e test periodici di recovery

5. Best practice di sicurezza

Elenca le principali best practice che l'organizzazione dovrebbe adottare per migliorare la propria postura di sicurezza e ridurre la superficie di attacco.

Raccomandazioni di sicurezza

Dall'analisi degli scenari di attacco ransomware emergono alcune misure fondamentali che le organizzazioni dovrebbero adottare per migliorare la propria sicurezza informatica.

Controlli tecnici

- implementazione di soluzioni **EDR/XDR** sugli endpoint
- utilizzo di sistemi **SIEM** per il monitoraggio centralizzato dei log
- applicazione regolare delle patch di sicurezza
- protezione degli accessi remoti tramite **VPN sicure e MFA**

Sicurezza della rete

- segmentazione della rete aziendale
- limitazione dei privilegi degli utenti
- monitoraggio del traffico di rete

Protezione dei dati

- backup regolari e offline
- test periodici delle procedure di ripristino
- cifratura dei dati sensibili

Formazione degli utenti

- programmi di **security awareness**
- simulazioni di phishing
- formazione sulle buone pratiche di sicurezza informatica

Incident Response

È fondamentale che le organizzazioni dispongano di un **Incident Response Plan** per reagire rapidamente a eventuali attacchi ransomware.

Il piano dovrebbe includere:

- procedure di isolamento dei sistemi compromessi
- comunicazione interna e gestione dell'incidente
- analisi forense dell'attacco
- ripristino dei sistemi tramite backup
- miglioramento delle difese dopo l'incidente

Conclusione

La simulazione di attacchi ransomware rappresenta uno strumento efficace per individuare le vulnerabilità presenti nelle infrastrutture informatiche aziendali.

L'utilizzo di prompt strutturati per sistemi di intelligenza artificiale consente di supportare le organizzazioni nella valutazione delle proprie difese e nella definizione di strategie di sicurezza più efficaci.

Attraverso l'integrazione di metodologie come il **MITRE ATT&CK Framework**, il **NIST Cybersecurity Framework** e i principi di **Zero Trust**, è possibile migliorare significativamente la resilienza delle infrastrutture IT contro le minacce ransomware.

Venezia, 05/03/2026

Fabio Renna